

This API design focuses on **security, HIPAA compliance, and developer experience** for the AI-Powered Hospital Management System.

1. API Overview

- **Base URL:** `https://api.hospital-system.com/v1`
- **Protocol:** HTTPS only.
- **Data Format:** JSON.
- **Version:** v1 (via URL path).
- **Global Headers:**
 - * `Authorization: Bearer`
 - * `X-Request-ID:` (for request tracing)

2. Authentication

- **Method:** OAuth 2.0 / OpenID Connect.
- **Flow:** JWT-based stateless authentication.
- **Scopes:** `patient:read`, `patient:write`, `appointment:manage`, `ehr:write`, `admin:full`.
- **Token Expiry:** 15 minutes (with refresh token rotation).

3. Key Endpoints

Method	Endpoint	Description	Role Required
POST	<code>/auth/login</code>	Authenticate and obtain JWT	Any
POST	<code>/triage</code>	Submit symptoms for AI analysis	Reception/Triage
GET	<code>/patients/{id}/ehr</code>	Retrieve full EHR history	Doctor/Admin
POST	<code>/ehr/{id}/verify</code>	Sign-off on AI diagnostic suggestion	Doctor
GET	<code>/resources/availability</code>	Get real-time bed/staffing status	Admin

4. Request/Response Examples

AI-Assisted Triage (FR3)

POST `/triage`

```
{
  "patient_id": "uuid-123",
  "symptoms": ["chest pain", "shortness of breath"],
  "vitals": { "heart_rate": 110, "spo2": 92 }
}
```

Response (200 OK)

```
{
  "triage_level": "CRITICAL",
  "ai_confidence_score": 0.94,
  "suggested_priority": 1
}
```

Clinician AI Sign-off (Business Rule)

POST `/ehr/{record\_id}/verify`

```
{
  "clinician_id": "doctor-uuid",
  "verification_note": "Verified AI diagnosis for acute myocardial infarction.",
  "status": "APPROVED"
}
```

5. Status Codes

- ****200 OK:**** Success.
- ****201 Created:**** Resource (Appointment/Record) successfully created.
- ****400 Bad Request:**** Validation error (e.g., missing mandatory medical data).
- ****401 Unauthorized:**** Missing or invalid token.
- ****403 Forbidden:**** Authenticated user lacks sufficient permissions (e.g., Receptionist trying to edit EHR).
- ****422 Unprocessable Entity:**** AI validation failed (e.g., human-in-the-loop missing).

6. Validation & Error Responses

All errors will follow the RFC 7807 problem details standard.

Example Error Response (422 Unprocessable Entity)

```
{
  "type": "https://api.hospital.com/errors/ai-verification-required",
  "title": "Clinical Sign-off Missing",
  "status": 422,
  "detail": "AI diagnostic suggestion requires clinician verification before finalization.",
  "instance": "/v1/ehr/record-uuid/verify"
}
```

7. Security & Compliance (Architectural Notes)

- Request Validation:** All incoming data is sanitized against SQL injection and XSS.
- Audit Trail:** A middleware will intercept all `PATCH`/`POST` requests to `EHR` endpoints, logging the `user_id`, `timestamp`, and `request_payload` into an immutable ledger (audit table).
- Data Masking:** For non-clinical roles (e.g., analytics dashboards), PHI fields are masked at the API Gateway level.
- Rate Limiting:** Implemented per user role. Clinicians have higher throughput limits than public patient portals to ensure NFR4 performance.
- Human-in-the-Loop Enforcement:** The API will reject requests to move a status to `finalized` if the `AI_Audit_Log` table lacks an entry for that specific `record_id` with a non-null `clinician_id`.